TP 2 Jour 1: Installation, Configuration et Sécurisation MQTT sur Ubuntu

Anne-Laure JEAN LOUIS PRS CS 26.3

1. Préparation Système et installation Mosquitto

Nous démarrons par l'installation du système sur une machine Ubuntu. En faisant les commandes suivantes :

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y curl gnupg2 ca-certificates software-properties-common
lsb-release docker.io docker-compose mosquitto-clients net-tools
sudo systemctl enable --now docker
lsb_release -a
sudo usermod -aG docker $USER  # Relogin
```

```
aljl@aljl-VMware-Virtual-Platform:~$ sudo apt install -y curl gnupg2 ca-certific
ates software-properties-common lsb-release docker.io docker-compose mosquitto-c
lients net-tools
[sudo] Mot de passe de aljl :
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
ca-certificates est déjà la version la plus récente (20240203).
ca-certificates passé en « installé manuellement ».
software-properties-common est déjà la version la plus récente (0.99.49.4).
software-properties-common passé en « installé manuellement ».
lsb-release est déjà la version la plus récente (12.0-2).
lsb-release passé en « installé manuellement ».
Les paquets suivants ont été installés automatiquement et ne sont plus nécessair
es :
```

Nous installons le broker open source Mosquitto et Docker un orchestrateur. Nous configurons les droits pour l'utilisateur de la vm.

Une fois l'installation effectuée nous passons à la deuxième étape qui est l'installation.

Nous faisons ces commandes.

```
sudo add-apt-repository ppa:mosquitto-dev/mosquitto-ppa -y
sudo apt update && sudo apt install -y mosquitto mosquitto-clients
sudo systemctl enable --now mosquitto
ss -tulnp | grep 1883
```

```
aljl@aljl-VMware-Virtual-Platform:~$ sudo add-apt-repository ppa:mosquitto-dev/mosquitto-ppa -y
[sudo] Mot de passe de aljl :
PPA publishes dbgsym, you may need to include 'main/debug' component
Dépôt : « Types: deb
URIs: https://ppa.launchpadcontent.net/mosquitto-dev/mosquitto-ppa/ubuntu/
Suites: noble
Components: main
 »
Plus d'informations : https://launchpad.net/~mosquitto-dev/+archive/ubuntu/mosquitto-ppa
Ajout du dépôt.
Atteint :1 http://archive.ubuntu.com/ubuntu noble InRelease
Atteint :2 http://archive.ubuntu.com/ubuntu noble-updates InRelease
Atteint :3 http://archive.ubuntu.com/ubuntu noble-backports InRelease
Atteint :4 http://security.ubuntu.com/ubuntu noble-security InRelease
Réception de :5 https://ppa.launchpadcontent.net/mosquitto-dev/mosquitto-ppa/ubuntu noble InRelease [24,3 kB]
Réception de :6 https://ppa.launchpadcontent.net/mosquitto-dev/mosquitto-ppa/ubuntu noble/main amd64 Packages [2 080 B]
Réception de :7 https://ppa.launchpadcontent.net/mosquitto-dev/mosquitto-ppa/ubuntu noble/main Translation-en [1 268 B]
27,7 ko réceptionnés en 3s (11,0 ko/s)
Lecture des listes de paquets... Fait
aljl@aljl-VMware-Virtual-Platform:~$ sudo apt update && sudo apt install -y mosquitto mosquitto-clients
Atteint :1 https://ppa.launchpadcontent.net/mosquitto-dev/mosquitto-ppa/ubuntu noble InRelease
Atteint :2 http://archive.ubuntu.com/ubuntu noble InRelease
Atteint :3 http://security.ubuntu.com/ubuntu noble-security InRelease
Atteint :4 http://archive.ubuntu.com/ubuntu noble-updates InRelease
Atteint :5 http://archive.ubuntu.com/ubuntu noble-backports InRelease
Lecture des listes de paquets... Fait
```

Ici, nous vérifions que la communication se fait bien sur le port 1883.

```
aljl@aljl-VMware-Virtual-Platform:~$ ss -tulnp | grep 1883
tcp   LISTEN 0      100        127.0.0.1:1883       0.0.0.0:*
tcp   LISTEN 0      100            [::1]:1883          [::]:*
```

Nous testons que le broker fonctionne correctement :

```
aljl@aljl-VMware-Virtual-Platform:~$ mosquitto_sub -h localhost -t "test/topic" -v &
[1] 7815
aljl@aljl-VMware-Virtual-Platform:~$ mosquitto_pub -h localhost -t "test/topic" -m "Hello MQTT"
test/topic Hello MQTT
```

Nous passons à la sécurisation.

3. Sécurisation

Nous allons sécuriser le broker. Cela se fait en trois étapes.

1. Authentification

Dans le fichier de configuration mosquitto.conf, nous forçons l'authentifications en passant allow_anonymous à false au lieu de true. N'importe qui, ne pourra pas se connecter.

```
  GNU nano 7.2
# Place your local configuration in /etc/mosquitto/conf.d/
#
# A full description of the configuration file is at
# /usr/share/doc/mosquitto/examples/mosquitto.conf.example

#pid_file /run/mosquitto/mosquitto.pid

persistence true
persistence_location /var/lib/mosquitto/

log_dest file /var/log/mosquitto/mosquitto.log

#include_dir /etc/mosquitto/conf.d

allow_anonymous false
password_file /etc/mosquitto/passwd
```

Un fichier chiffré avec les identifiants des utilisateurs utilisés est créé, grâce à la commande mosquito_passwd. Ici l'utilisateur est le user1.

Pour que le service mosquitto fonctionne, il est nécessaire de donner la propriété du fichiers de mots de passe au service mosquito. Nous le faisons avec la commande suivante : sudo chown mosquitto:mosquitto /etc/mosquitto/passwd.

Nous restreignons les droits pour que seul le service mosquito puisse le lire : sudo chmod 600 /etc/mosquitto/passwd.

Le service est redémarré.

2. TLS

Nous allons sécurisé les communications. Pour ce faire, nous générons des certificats en RSA 2048 bits et des clefs avec open ssl.

```
aljl@aljl-VMware-Virtual-Platform:~$ sudo openssl req -x509 -nodes -days 365 -ne
wkey rsa:2048   -keyout /etc/mosquitto/server.key -out /etc/mosquitto/server.crt
   -subj "/CN=localhost"
...+..+.........+.........+..+................+.........+++++++++++++++
++++++++++++++++++++++++++++++++++++++++++++++*....+......++++++++++++++++++
++++++++++++++++++++++++++++++++++++++++++++*.+.+.........+........+...+......+
...+.+.....+......+...+.+..+.......+...+.....+...+.......+.............+.+.....
.........+.........+....+......+.........+.....+................+++++++++++++++
++++++++++++++++++++++++++++++++++++++++++++++
..+....+.....+.+.....+............+.........+..+.............+.....+......+.+++
+++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++*..+.......+++++++
++++++++++++++++++++++++++++++++++++++++++++++++++++++++*...................+..
.....+..+..........+.............+......+......+....+...+..+.........+.+...+...
+...+..+.......+..+.+..+............+............+......+...+.......+...+....
.+.......+..+.+..........+.........+...+.....+.......+...+..+.........+......
..+.+..+.......+........+...+.........+.........+.....+...+.........+....+.....
+....+...+.....+.......+................+.+........+.+.....+............+...+.
....+...+......+......+....+...........+....+++++++++++++++++++++++++++++++++
```

Dans le fichier de configuration, nous ajoutons le port d'écoute 8883 pour utiliser le MQTT chiffré.

```
  GNU nano 7.2                /etc/mosquitto/mosquitto.conf
# Place your local configuration in /etc/mosquitto/conf.d/
#
# A full description of the configuration file is at
# /usr/share/doc/mosquitto/examples/mosquitto.conf.example

#pid_file /run/mosquitto/mosquitto.pid

persistence true
persistence_location /var/lib/mosquitto/

log_dest file /var/log/mosquitto/mosquitto.log

#include_dir /etc/mosquitto/conf.d

allow_anonymous false
password_file /etc/mosquitto/passwd
listener 8883
cafile /etc/mosquitto/server.crt
certfile /etc/mosquitto/server.crt
keyfile /etc/mosquitto/server.key
```

3. ACL

Nous restreignons les droits dans un fichier /etc/mosquitto/aclfile. Nous donnons les droits de lecture et ecriture sur le topic test. Mais sur le topic maison/temperature, les droits sont en lecture seule.

```
  GNU nano 7.2                    /etc/mosquitto/aclfile
user user1
topic readwrite test/#
topic read maison/temperature
```

4. Docker Compose

Nous créons un fichier yaml qui orchestrera le broker.

```
  GNU nano 7.2                    docker-compose.yml
version: '3.8'
services:
  mqtt-broker:
    image: eclipse-mosquitto:2.0
    ports: ["1883:1883", "9001:9001"]
    volumes:
      - ./mosquitto.conf:/mosquitto/config/mosquitto.conf:ro
      - mosquitto_data:/mosquitto/data
volumes:
  mosquitto_data:
docker-compose up -d
docker-compose logs
```

5. Sécurité IoT MQTT

Nous reconfigurons le fichier mosquitto.conf pour lui ajouter la partie acl.

```
  GNU nano 7.2                    /etc/mosquitto/mosquitto.conf

#pid_file /run/mosquitto/mosquitto.pid

persistence true
persistence_location /var/lib/mosquitto/

log_dest file /var/log/mosquitto/mosquitto.log

#include_dir /etc/mosquitto/conf.d

allow_anonymous false
password_file /etc/mosquitto/passwd
listener 8883
cafile /etc/mosquitto/server.crt
certfile /etc/mosquitto/server.crt
keyfile /etc/mosquitto/server.key

acl_file /etc/mosquitto/aclfile
```

6. Tests Sécurité

L'authentification et le TLS fonctionnent.

```
aljl@aljl-VMware-Virtual-Platform:~$ mosquitto_pub -h localhost -t test -m 'anon'
Error: Connection refused
```

```
aljl@aljl-VMware-Virtual-Platform:~$ mosquitto_pub -h localhost -p 8883 --cafile /etc/mosquitto/server.crt -u "user1" -P "password" -t "test" -m "auth"
aljl@aljl-VMware-Virtual-Platform:~$ cd /etc/mosquitto/
aljl@aljl-VMware-Virtual-Platform:/etc/mosquitto$ ls
```

Réponses aux questions

Pour chaque risque identifié/vulnérabilité, proposez au moins une mesure de mitigation concrète.

```
# Utilisateur 'dashboard' : lecture seule sur tous les topics home/
user dashboard
topic read home/#
```

Ici, des droits de lecture sont donnés sur tout le topic home/ comme on peut le voir avec le hashtag. Il serait mieux au niveau sécurité de préciser ce que doit lire le dashboard avec une granularité plus fine, s'il doit lire une température par exemple. En effet, tous les sous topics peuvent être lus. La restriction se fait via les ACL.

```
# Utilisateur 'sensor_node_1' : lecture/écriture sur son topic uniquement
user sensor_node_1
topic readwrite home/sensor1/#
```

Ici, les droits donnés sont lecture et écriture. Il faudrait se limiter à des droit de lecture seule afin d'atténuer le risque d'injection.

7. Bonnes Pratiques & Diagnostic

Firewall et logs mosquitto

```
aljl@aljl-VMware-Virtual-Platform: $ sudo ufw allow 8883
[sudo] Mot de passe de aljl :
Les règles ont été mises à jour
Les règles ont été mises à jour (IPv6)
aljl@aljl-VMware-Virtual-Platform: $ journalctl -u mosquitto -f
mars 31 11:02:37 aljl-VMware-Virtual-Platform systemd[1]: mosquitto.service: Deactivated successfully.
mars 31 11:02:37 aljl-VMware-Virtual-Platform systemd[1]: Stopped mosquitto.service - Mosquitto MQTT Broker.
mars 31 11:02:37 aljl-VMware-Virtual-Platform systemd[1]: mosquitto.service: Consumed 1.561s CPU time.
mars 31 11:02:37 aljl-VMware-Virtual-Platform systemd[1]: Starting mosquitto.service - Mosquitto MQTT Broker...
mars 31 11:02:37 aljl-VMware-Virtual-Platform systemd[1]: Started mosquitto.service - Mosquitto MQTT Broker.
mars 31 11:05:01 aljl-VMware-Virtual-Platform systemd[1]: Stopping mosquitto.service - Mosquitto MQTT Broker...
mars 31 11:05:01 aljl-VMware-Virtual-Platform systemd[1]: mosquitto.service: Deactivated successfully.
mars 31 11:05:01 aljl-VMware-Virtual-Platform systemd[1]: Stopped mosquitto.service - Mosquitto MQTT Broker.
mars 31 11:05:01 aljl-VMware-Virtual-Platform systemd[1]: Starting mosquitto.service - Mosquitto MQTT Broker...
mars 31 11:05:01 aljl-VMware-Virtual-Platform systemd[1]: Started mosquitto.service - Mosquitto MQTT Broker.
```

8. Questions

Quels risques si MQTT non sécurisé ?

Il y a plusieurs risques, il y a des risques d'usurpation d'identité à cause d'un manque d'authentification, si une personne arrive à accéder au broker sans authentification il y a un risque de vols de données et d'exposition. Avec des topics permissifs (utilisation de # en lecture et ecriture), il est possible d'injecter de la données. Aussi, si le port 1883 (en clair) est utilisé une attaque man in the middle est possible.

Différence TLS/mTLS ?

Avec le TLS seul le broker sera authentifié contrairement au mTLS (m pour mutual) qui impose une authenfitication pour le broker et le client. Le client présente son certificat au broker qui l'accepte.

Pourquoi ACL ?

Les ACL permettent d'avoir une gestion des droits d'accès plus fine. On peut y définir des rôles comme on l'a vu avec des droits définis pour un utilisateur. ACL signifie access control list. On y peut définir qui à accès à quoi.